

Manuel des procédures sécurité — DGCPT

Audit Platform

Plateforme d'audit — Documentation · Généré le 15 mai 2026

Document de référence RSSI / exploitation pour la plateforme entreprise d'audit et de contrôle interne.

1. Périmètre et objectifs

1.1 Périmètre

- Application web Laravel (missions, workflows, risques, SWOT/RACI, IA)
- API REST v1 (Sanctum)
- Files d'attente et projections
- Journaux d'audit IAM et immutable

1.2 Objectifs sécurité

1. **Confidentialité** — isolation par département (tenant)
 2. **Intégrité** — chaîne d'audit hashée, actions runtime signées
 3. **Traçabilité** — qui / quoi / quand / depuis quelle IP
 4. **Disponibilité** — files, recovery, monitoring
 5. **Non-répudiation** — validations humaines explicites
-

2. Modèle de menaces (synthèse)

Menace	Contrôle
Accès cross-pôle	Tenant isolation middleware
Élévation de privilèges	Gates IAM + policies
Session hijacking	Session governance (IP binding optionnel)
Injection / XSS	Validation Laravel, sanitization IA
Fuite données via IA	Driver on-premise, pas d'auto-envoi masse
Altération logs	Immutable audit chain
Abus API	Rate limit + signatures optionnelles

3. Procédures d'authentification

PROC-SEC-001 — Gestion des comptes

Étape	Action	Responsable
1	Demande validée par manager	Manager pôle
2	Création compte <code>approved</code>	Admin IAM
3	Attribution rôle moindre privilège	Admin IAM
4	Vérification journal <code>user_created</code>	Admin sécurité
5	Communication identifiants (canal sécurisé)	Admin IAM

PROC-SEC-002 — Révocation d'accès

1. Désactiver compte (`deactivate`) — immédiat.
2. Vérifier sessions invalidées.
3. Soft-delete si départ définitif.
4. Conserver `audit_logs` et `immutable_audit_events` .

PROC-SEC-003 — Réponse aux échecs de connexion

1. Consulter `/admin/security/audit-logs` (filtre `login_failure`).
 2. 5 échecs / 15 min sur même compte → vérifier verrouillage `account_locked` .
 3. Si attaque distribuée → bloquer IP au WAF + alerter RSSI.
-

4. Procédures isolation tenant

PROC-SEC-010 — Vérification isolation

Fréquence : trimestrielle

1. Créer 2 utilisateurs de pôles différents (A et B).
2. Utilisateur A tente d'ouvrir mission du pôle B via URL directe.
3. **Résultat attendu** : HTTP 403 « hors périmètre tenant ».
4. Documenter dans registre de tests.

PROC-SEC-011 — Nouveau département

1. Créer département dans `/admin/departments` .
 2. Vérifier création `tenant_contexts` + `tenant_security_policies` .
 3. Configurer `allowed_modules` si restriction nécessaire.
-

5. Procédures audit trail

PROC-SEC-020 — Vérification chaîne immutable

Fréquence : hebdomadaire (automatable)

1. Accéder `/observability/enterprise/security` .
2. Vérifier **Chaîne audit vérifiée : OK**.
3. Si rupture (`hash_chain_break`) :
 - STOP traitements sensibles
 - Export `immutable_audit_events` autour de `broken_at`
 - Incident sécurité P1

PROC-SEC-021 — Conservation des logs

Journal	Rétention recommandée
<code>audit_logs</code> (IAM)	7 ans (réglementaire)
<code>immutable_audit_events</code>	7 ans
<code>ai_execution_logs</code>	2 ans
<code>swot_audit_logs</code> / <code>raci_audit_logs</code>	5 ans

6. Procédures runtime workflow

PROC-SEC-030 — Validation des transitions sensibles

Toute action `approve`, `reject`, `rollback` :

1. Est enregistrée dans audit immutable (`workflow_async_dispatch` / transitions).
2. Peut être signée HMAC si `ENTERPRISE_SIGNED_RUNTIME=true` .
3. **Interdiction** d'automatiser via IA ou script externe sans cadre formel.

PROC-SEC-031 — Revue des rejets massifs

1. Observability → erreurs / événements métier.
2. Filtrer `reject` > seuil sur une mission.
3. Analyse cause : formation ou fraude interne.

7. Procédures IA

PROC-SEC-040 — Activation LLM production

Étape	Action
1	DPIA / analyse impact (données mission)
2	Choix driver (Ollama on-premise recommandé données sensibles)
3	<code>AI_COPILOT_DRIVER</code> + clés dans coffre (pas git)
4	Vérifier <code>AI_COPILOT_ENABLED=true</code>
5	Test mission pilote + revue recommandations
6	Formation « assistive only »

PROC-SEC-041 — Incident prompt injection

- Désactiver temporairement : `AI_COPILOT_ENABLED=false` .
- Exporter `ai_execution_logs` + prompts hashés.
- Renforcer patterns `AiModerationService` si besoin.
- Réactivation après validation RSSI.

PROC-SEC-042 — Recommandations IA non validées

- `/ai/analytics` → pending validation.
 - Relance mensuelle aux chefs de mission.
 - Les recommandations **ne déclenchent aucune action** sans clic humain explicite.
-

8. Procédures API

PROC-SEC-050 — Tokens Sanctum

- Émission tokens par utilisateur identifié uniquement.
- Rotation annuelle ou à la révocation compte.
- Révoquer tous tokens si compromission.

PROC-SEC-051 — Durcissement API (optionnel)

```
ENTERPRISE_API_SIGNATURES=true
```

Headers requis :

- X-Api-Signature
- X-Api-Timestamp

Middleware : `api.hardening` sur routes `/api/v1/*`.

9. Chiffrement et secrets

Secret	Stockage
APP_KEY	Env serveur
ENTERPRISE_SIGNING_KEY	Env (défaut APP_KEY)
ENTERPRISE_PAYLOAD_KEY	Env — chiffrement payloads sensibles
OPENAI_API_KEY	Coffre secrets

PROC-SEC-060 — Rotation `APP_KEY` : suivre runbook Laravel (maintenance + re-chiffrement).

10. Classification des incidents

Niveau	Exemple	Délai réponse
P1	Rupture chaîne audit, fuite cross-tenant	< 1 h
P2	Pic échecs auth, driver IA compromis	< 4 h
P3	Job queue bloquée, lenteur	< 24 h
P4	Anomalie mineure UI	Prochain sprint

11. Registre des contrôles (mapping)

Contrôle	Implémentation technique
AC-1 Comptes nominatifs	Users + IAM
AC-2 Moindre privilège	Roles + permissions
AU-2 Audit events	audit_logs + immutable
SC-8 Confidentialité transit	HTTPS obligatoire
IA-1 Assistive only	ai_copilot.php flags
TN-1 Séparation pôles	tenant_contexts

12. Voir aussi

- [Guide exploitation](#)
 - [Guide admin](#)
-